NETWORKING

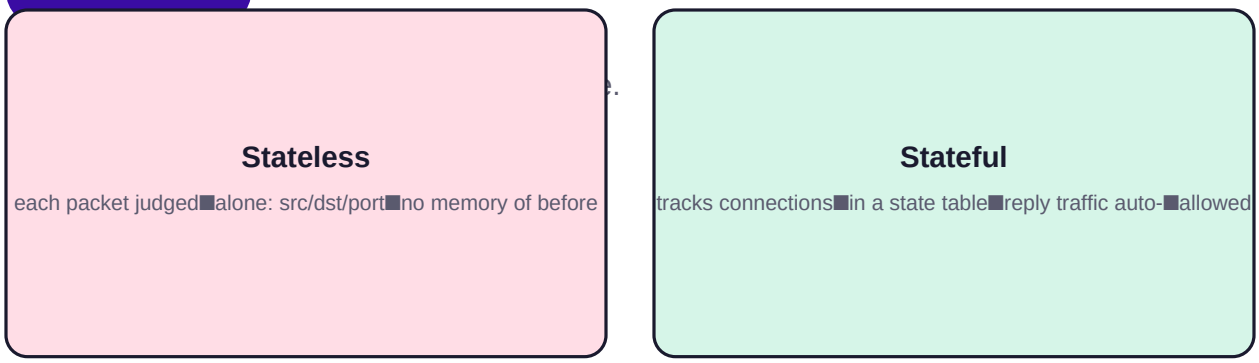
Firewalls Visual Guide

Drawing the line —
stateless vs stateful, zones, and rule craft.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/5

Stateless vs Stateful



- Stateless: fast, simple — but return traffic needs explicit mirror rules, and it's blind to context.
- Stateful: remembers the 5-tuple of every connection; ACKs for known sessions pass automatically.
- Modern firewalls are stateful by default; stateless survives in high-speed ACLs and DDoS scrubbing.

STEP 2/5

Zones: Trust Has Geography

Segment the network so one breach doesn't own everything.

- DMZ hosts are reachable from the internet but isolated from the interior — a compromised web server can't pivot freely.
- Default flows: internet → DMZ (limited ports), internal → anywhere, DMZ → internal (almost nothing).
- Cloud version: public subnets, private subnets, and security groups per tier — same idea, new names.

STEP 3/5

Rule Ordering Matters

First match wins — order is the policy.

1. ALLOW established

return traffic for known connections

2. ALLOW 443 → web DMZ

public HTTPS in

3. ALLOW internal → any

outbound browsing

4. DENY all

implicit — the safety net

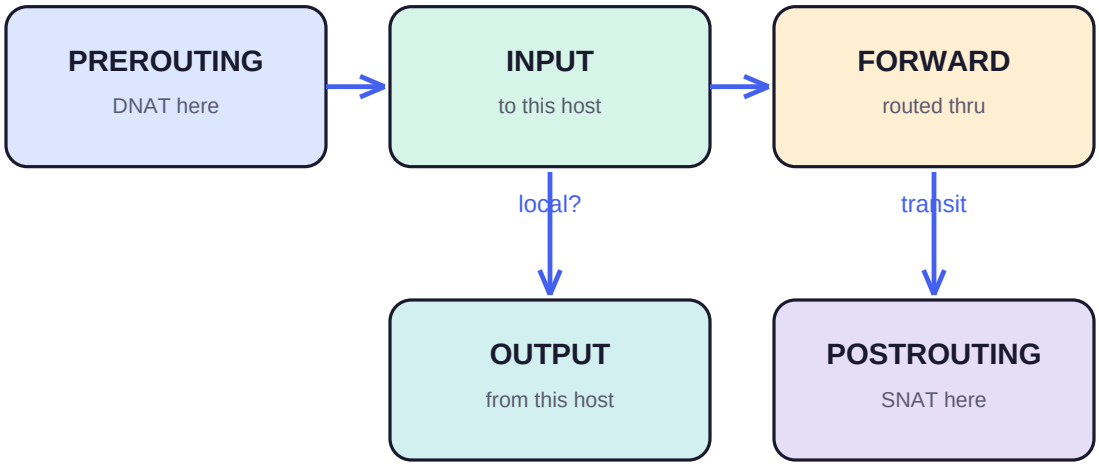
A broad ALLOW above a narrow DENY silently defeats it — audit top-down, most specific first.

Default-deny: if no rule matches, DROP. Every firewall policy should end with an explicit deny-all.

STEP 4/5

iptables Chain Flow

Packets walk chains; each chain is an ordered rule list.



nftables unifies this into one engine, but the chain mental model carries over.

STEP 5/5

Beyond Packets: NGFW & WAF

Modern firewalls read up the stack.

Next-gen firewall (NGFW)

App-aware: 'allow Slack, block BitTorrent' — not just ports. TLS inspection, IDS/IPS built in.

WAF

HTTP-layer: blocks SQLi, XSS, and OWASP Top-10 patterns before they reach the app.

Egress filtering

Control what's allowed OUT — malware phones home; don't let it.

Defense in depth: packet filter at the edge, WAF in front of apps, host firewall on every machine.

STEP ✓/✓

Key Takeaways

Firewalls — Remember

- Stateless judges packets alone; stateful tracks connections and auto-allows replies.
- Zones (internet / DMZ / internal) contain breaches — limit DMZ→internal to near zero.
- Rules are first-match-wins: order most-specific first, end with explicit deny-all.
- iptables chains: PREROUTING → INPUT/FORWARD → OUTPUT → POSTROUTING.
- Layer up: NGFW for apps, WAF for HTTP attacks, egress filtering for exfiltration.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev